

Cyber Security

Cybersecurity Frameworks

By
Dr. Mudassar Raza
Professor
Department of Computer Science
Namal University Mianwali



https://techgirls.ece.vt.edu/slides/introduction_to_cybersecurity.html#39

Information Security

- Preservation of confidentiality, integrity, and availability of information
- Other properties such as authenticity, accountability, non-repudiation, and reliability can also be involved

Network Security

- Protection of networks and their services from unauthorized modification, destruction, or disclosure and provision of assurance that the network performs its critical function correctly and that there are no harmful side effects

The Value of Standards and best practices documents

- Several organizations have developed best practices **types of documents** as well as **standards** for implementing and evaluating cybersecurity
 - National Institute of Standards and Technology (NIST)
 - ITU-T
 - International Organization for Standardization (ISO)
 - Internet Society (ISOC)
- A number of professional and industry groups have produced best practices **documents and guidelines**
 - The most important document is the **Standard of Good Practice for Information Security**, produced by the Information Security Forum (ISF)
 - This 300+ page document provides a wide range of best practices representing the consensus of industry and government organizations
 - Other respected organizations, including the Information Systems Audit and Control Association (ISACA) and the Payment Card Industry (PCI) have produced a number of similar documents

Most prominent best practices and standards documents

Source	Title	Date
Information Security Forum	The Standard of Good Practice for Information Security	2016
International Standards Organization	ISO 27002—Code of Practice for Information Security Controls	2013
NIST	Framework for Improving Critical Infrastructure Cybersecurity	2017
Center for Internet Security	The CIS Critical Security Controls for Effective Cyber Defense Version 7	2018
ISACA	COBIT 5 for Information Security	2012
PCI Security Standards Council	Data Security Standard v3.2—Requirements and Security Assessment Procedures	2016

The standard of good practice for information security (SGP)

- The **ISF** is an independent, not-for-profit association of leading organizations from around the world
 - ISF members **fund and cooperate** in the development of a practical **research program in information security**
 - It is dedicated to investing, clarifying, and resolving key issues in cybersecurity, information security, and risk management and to developing best practice methodologies, processes, and solutions that meet the business needs of its members
- The most significant activity of the ISF is the ongoing **development** of the **Standard of Good Practice** for Information Security (SGP)
 - This document is a business-focused comprehensive guide to identifying and managing information security risks in organizations and their supply chains
 - The SGP is based on research projects and input from ISF members as well as analysis of the leading standards on cybersecurity, information security, and risk management

ISF Framework

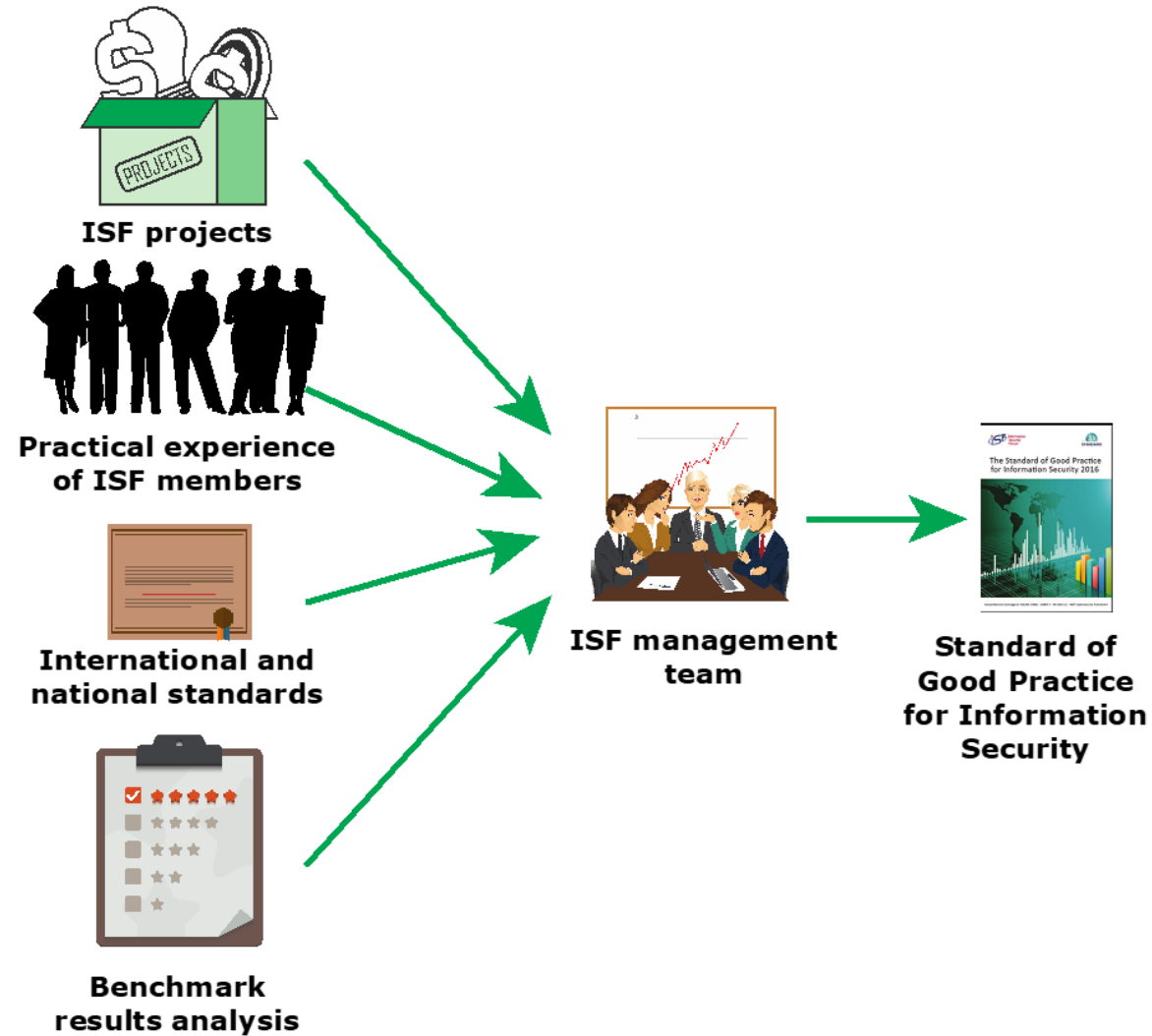


Figure 1.2 Basis for the ISF Standard of Good Practice

SGP is of interest to the following individuals:

Chief information security officers (or equivalent)	Responsible for developing policy and implementing sound information security governance and information security assurance
Information security managers	Responsible for promoting or implementing an information security assurance program
Business managers	Responsible for ensuring that critical business applications, processes, and local environments on which an organization's success depends are effectively managed and controlled
IT managers and technical staff	Responsible for designing, planning, developing, deploying, and maintaining key business applications, information systems, or facilities
Internal and external auditors	Responsible for conducting security audits
IT service providers	Responsible for managing critical facilities (for example, computer installations, networks) on behalf of the organization
Procurement and vendor management teams	Responsible for defining appropriate information security requirements in contracts

Security Policy

A set of rules and practices that specify or regulate how a system or organization provides security services to protect sensitive and critical system resources

Table 1.2

ISF Standard of Good Practice for Information Security: Categories and Areas

(Table is on pages 10-11 in the textbook)

SECURITY GOVERNANCE (SG)	SYSTEM ACCESS (SA)
Security Governance Approach	Access Management
Security Governance Components	Customer Access
INFORMATION RISK ASSESSMENT (IR)	SYSTEM MANAGEMENT (SY)
Information Risk Assessment Framework	System Configuration
Information Risk Assessment Process	System Maintenance
SECURITY MANAGEMENT (SM)	NETWORKS AND COMMUNICATIONS (NC)
Security Policy Management	Network Management
Information Security Management	Electronic Communication
PEOPLE MANAGEMENT (PM)	SUPPLY CHAIN MANAGEMENT (SC)
Human Resource Security	External Supplier Management
Security Awareness/Education	Cloud Computing
INFORMATION MANAGEMENT (IM)	TECHNICAL SECURITY MANAGEMENT (TS)
Information Classification and Privacy	Security Solutions
Information Protection	Cryptography
PHYSICAL ASSET MANAGEMENT (PA)	THREAT AND INCIDENT MANAGEMENT (TM)
Equipment Management	Cybersecurity Resilience
Mobile Computing	Security Incident Management
SYSTEM DEVELOPMENT (SD)	LOCAL ENVIRONMENT MANAGEMENT (LE)
System Development Management	Local Environments
System Development Life Cycle	Physical and Environmental Security
BUSINESS APPLICATION MANAGEMENT (BA)	BUSINESS CONTINUITY (BC)
Corporate Business Applications	Business Continuity Framework
End User Developed Applications	Business Continuity Process
	SECURITY MONITORING AND IMPROVEMENT (SI)
	Security Audit
	Security Performance

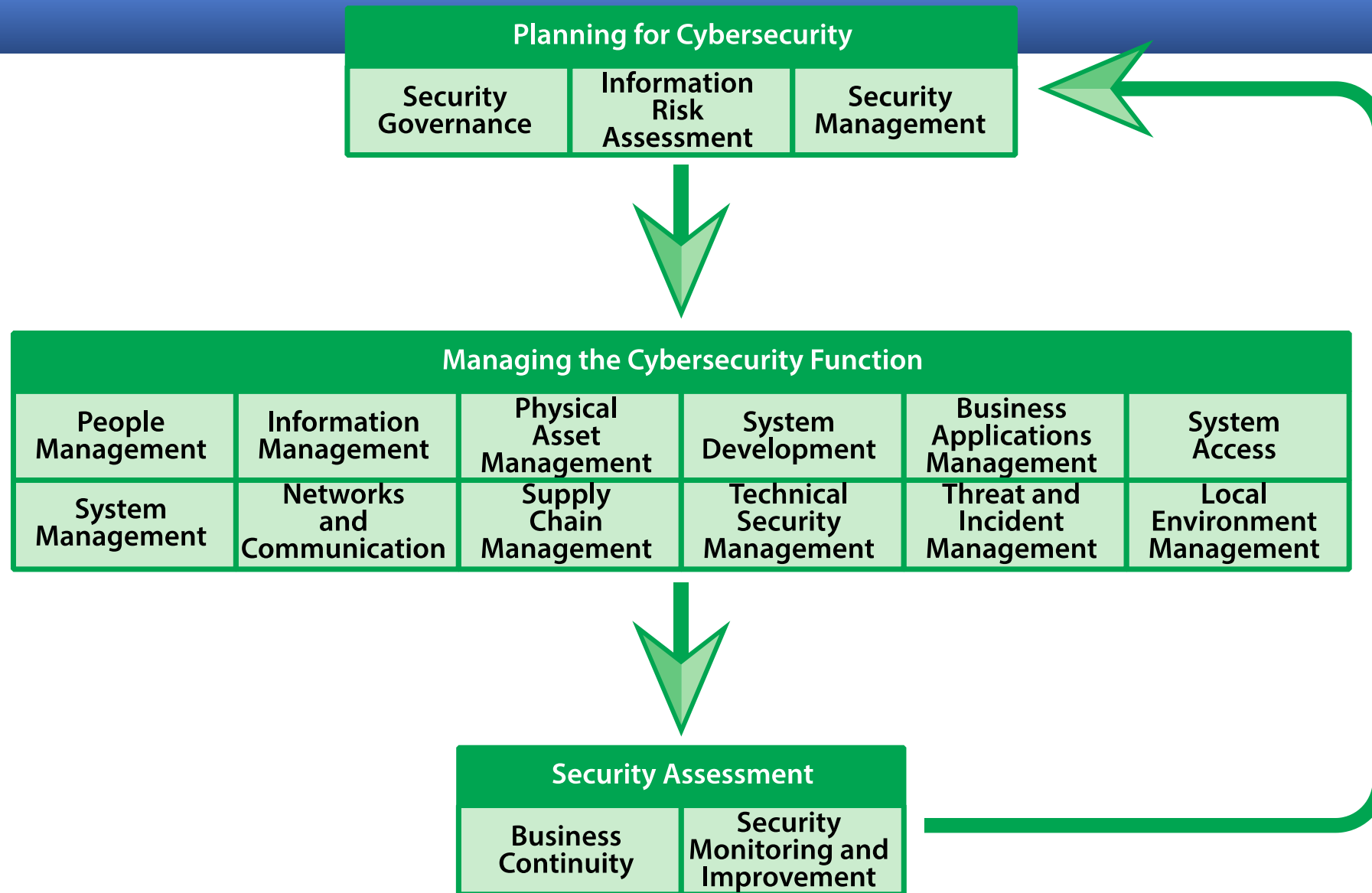


Figure 1.3 Categories in the Standard of Good Practice for Information Security

The iso/iec 27000 suite of information security standards

- ISO

- Perhaps the **most important** set of standards for cybersecurity
- Is an international agency for the development of standards on a wide range of subjects
- Founded in 1946
- It is a voluntary, nontreaty organization whose members are designated standards bodies of participating nations as well as nonvoting observer organizations
- The U.S. member body is the American National Standards Institute (ANSI)
- Has issued more than **12,000 standards** in a broad range of areas
- Its purpose is to promote the development of standardization and related activities to facilitate international exchange of goods and services and to develop cooperation in the sphere of intellectual, scientific, technological, and economic activity
- **One important area of ISO standardization deals with the Open System Interconnection (OSI) communications architecture and the standards at each layer of this architecture**

The iso/iec 27000 suite of information security standards

- IEC

- International Electrotechnical Commission
- Develops standards in a **joint effort with ISO** in the areas of data communications, networking, and security
- Primarily **concerned with electrical and electronic** engineering standards
- **In the area of information technology the IEC emphasis is on hardware and the ISO emphasis is on software**
- In 1997 the two groups formed the Joint Technical Committee 1 (JTC 1)
 - This committee has the responsibility of developing the documents that ultimately become ISO (and IEC) standards in the area of information technology

The iso/iec 27000 suite of information security standards

- The ISO and IEC have developed a growing family of standards in the ISO/IEC 27000 series that deal with ISMSs

Information security management system:

consists of the policies, procedures, guidelines, and associated resources and activities, collectively managed by an organization, in the pursuit of protecting its information assets. An ISMS is a systematic approach for establishing, implementing, operating, monitoring, reviewing, maintaining and improving an organization's **information security to achieve business objectives**. It is based upon a risk assessment and the organization's risk acceptance levels designed to effectively treat and manage risks.

ISMS overview and vocabulary	ISMS requirements		ISMS guidelines		ISMS sector-specific guidelines	
27000 ISMS overview	27001 ISMS requirements	27006 Audit and certification of ISMS	27002 Code of practice for IS controls	27003 ISMS imple- mentation	27010 Intersector/ interorganiza- tional comms	27011 Telecomms organizations
	27009 Sector-specific application		27004 ISM measurement	27005 IS risk management	27015 Financial services	27017 IS controls for cloud services
			27007 ISMS auditing	TR 27008 Auditors on IS control	27018 Protection of PII in public clouds	27019 Energy utility industry PCS
			27013 Integrated im- plementation of 27001/20000	27014 Governance of IS		
			TR 27016 Organizational economics	27036 IS for supplier relationships		

ISMS = Information Security
Management System
PII = personally identifiable information
PCS = process control systems

Figure 1.4 ISO 27000 ISMS Family of Standards

Mapping ISO 27001 to the ISF Standard of Good Practice

ISO 27001 Topic	ISG SGP Category
4.1 Understanding the Organization and Its Context	Security Governance
4.2 Understanding the Needs and Expectations of Interested Parties	Security Governance
4.3 Determining the Scope of the Information Security Management System	Security Management
4.4 Information Security Management System	Security Management
5.1 Leadership and Commitment	Security Governance
5.2 Policy Security Management	Security Management
5.3 Organizational Roles, Responsibilities and Authorities	Security Governance
6.1 Actions to Address Risks and Opportunities	Information Risk Assessment
6.2 Information Security Objectives and Planning to Achieve Them	Security Management
7.1 Resources	Security Management
7.2 Competence	People Management
7.3 Awareness	People Management
7.4 Communication	People Management
7.5 Documented Information	Security Management
8.1 Operational Planning and Control	Security Management
8.2 Information Security Risk Assessment	Information Risk Assessment
8.3 Information Security Risk Treatment	Information Risk Assessment
9.1 Monitoring, Measurement, Analysis and Evaluation	Security Monitoring and Improvement
9.2 Internal Audit	Security Monitoring and Improvement
9.3 Management Review	Security Monitoring and Improvement
10.1 Non-conformity and Corrective Action	Security Monitoring and Improvement
10.2 Continual Improvement	Security Monitoring and Improvement

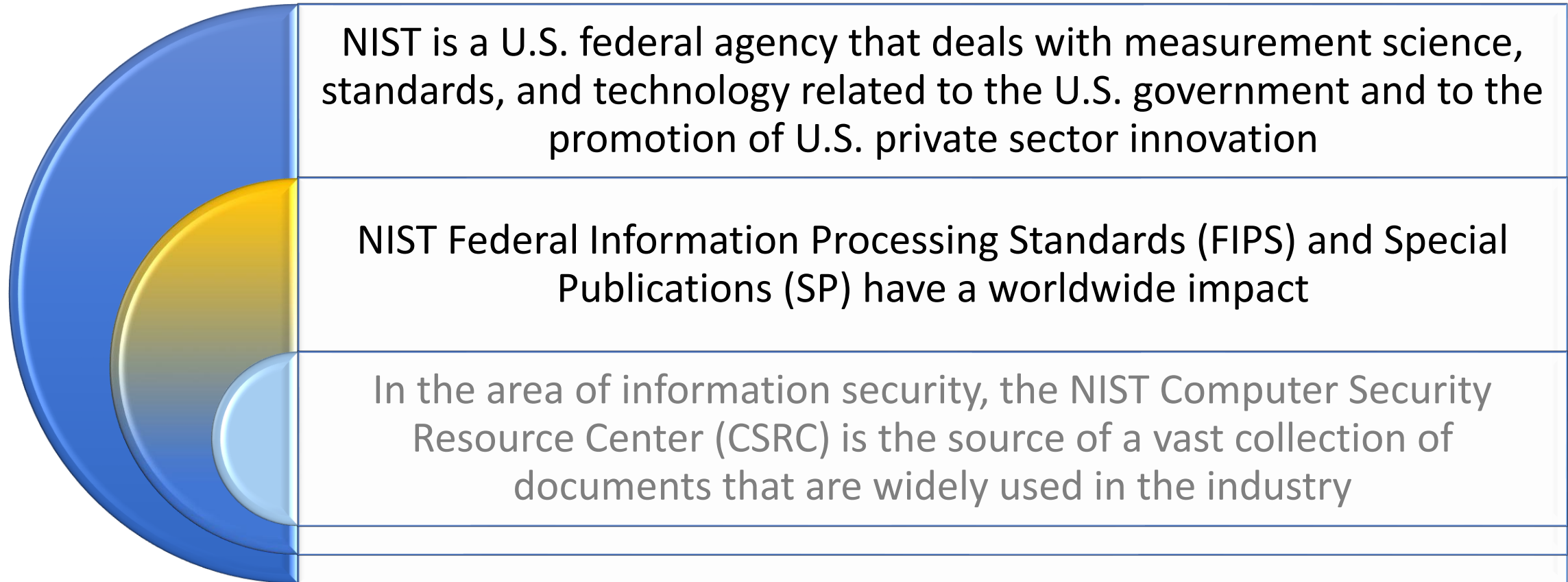
ISO 27001 Topic	ISG SGP Category
5.1 Management Direction for Information Security	Security Monitoring and Improvement
6.1 Internal Organization	Security Governance
6.2 Mobile Devices and Teleworking	People Management
7.1 Prior to Employment	People Management
7.2 During Employment	People Management
7.3 Termination and Change of Employment	People Management
8.1 Responsibility for Assets	Physical Asset Management
8.2 Information Classification	Physical Asset Management
8.3 Media Handling	Physical Asset Management
9.1 Business Requirements of Access Control	System Access
9.2 User Access Management	System Access
9.3 User Responsibilities	System Access
9.4 System and Application Access Control	System Access
10.1 Cryptographic Controls	Technical Security Management
11.1 Secure Areas	Local Environment Management
11.2 Equipment	Local Environment Management
12.1 Operational Procedures and Responsibilities	System Development
12.2 Protection from Malware	Technical Security Management
12.3 Backup	System Management
12.4 Logging and Monitoring	Threat and Incident Management
12.5 Control of Operational Software	System Development
12.6 Technical Vulnerability Management	System Development
12.7 Information Systems Audit Considerations	Security Monitoring and Improvement
13.1 Network Security Management	Networks and Communications
13.2 Information Transfer	Networks and Communications
14.1 Security Requirements of Information Systems	Security Management
14.2 Security in Development and Support Processes	System Development
14.3 Test Data	System Development
15.1 Information Security in Supplier Relationships	Supply Chain Management
16.1 Management of Information Security Incidents and Improvements	Threat and Incident Management
17.1 Information Security Continuity	Business Continuity
17.2 Redundancies	Business Continuity
18.1 Compliance with Legal and Contractual Requirements	Security Management
18.2 Information Security Reviews	Security Monitoring and Improvement

Mapping ISO 27002 to the ISF Standard of Good Practice

(Table is on pages 19-20 in the textbook)

By: Dr. Mudassar Raza

NIST cybersecurity framework and security documents



NIST Cybersecurity Framework Functions and Categories

Function	Description	Category
Identify	Develop the organizational understanding to manage cybersecurity risk to systems, assets, data, and capabilities.	Asset Management
		Business Environment
		Governance
		Risk Assessment
		Risk Management Strategy
		Supply Chain Risk Management
Protect	Develop and implement the appropriate safeguards to ensure delivery of critical infrastructure services.	Access Control
		Awareness and Training
		Data Security
		Information Protection Processes and Procedures
		Maintenance
		Protective Technology
Detect	Develop and implement the appropriate activities to identify the occurrence of a cybersecurity event.	Anomalies and Events
		Security Continuous Monitoring
		Detection Processes
Respond	Develop and implement the appropriate activities to take action regarding a detected cybersecurity event.	Response Planning
		Communications
		Analysis
		Mitigation
		Improvements
Recover	Develop and implement the appropriate activities to maintain plans for resilience and to restore any capabilities or services that were impaired due to a cybersecurity event.	Recovery Planning
		Improvements
		Communications

(Table is on page 23 in the textbook)

By: Dr. Mudassar Raza

Cybersecurity Framework Implementation Tiers

Risk Management Process	Integrated Risk Management Program	External Participation
Tier 1: Partial		
RM practices not formalized, ad hoc. Prioritization of cybersecurity activities may not be directly informed by organizational risk objectives, the threat environment, or business/mission requirements.	Limited awareness of risk, no organization-wide approach to RM. cybersecurity information to be shared within the organization.	Lack of coordination and collaboration with other entities.
Tier 2: Risk Informed		
RM practices approved by management by not established as organizational-wide policy. Informed prioritization of cybersecurity activities.	Risk-informed, processes and procedures are defined and implemented, and staff has adequate resources to perform their cybersecurity duties. No organization-wide approach to RM.	No formal coordination and collaboration with other entities.
Tier 3: Repeatable		
RM practices are formally approved and expressed as policy. Organizational cybersecurity practices are regularly updated based on changes in business/mission requirements and the threat and technology landscape.	Organization-wide approach to RM. Risk-informed policies, processes, and procedures are defined, implemented as intended, and reviewed. Personnel possess the knowledge and skills to perform their appointed roles and responsibilities.	Collaboration with partners enables RM decisions in response to external events.
Tier 4: Adaptive		
Organization actively adapts to a changing cybersecurity landscape and responds to evolving and sophisticated threats in a timely manner.	Organization-wide approach to managing cybersecurity risk that uses risk-informed policies, processes, and procedures to address potential cybersecurity events.	Organization manages risk and actively shares information with partners to ensure that accurate, current information is being distributed and consumed.

countermeasure

An action, a device, a procedure, or a technique that **reduces** a threat, a vulnerability, or an attack by eliminating or **preventing** it, by **minimizing the harm** it can cause, or by discovering and reporting it so that corrective action can be taken

NIST security documents

- SP 800-53, *Security and Privacy Controls for Federal Information Systems and Organizations* is by far the most significant document
- This document lists management, operational, and technical safeguards or countermeasures prescribed for an information system to protect the confidentiality, integrity, and availability of the system and its information
- Although intended for U.S. government systems, it is of equal applicability to IT systems in any organization
- State-of-the-practice security controls and control enhancements have been integrated into the latest revision (2013) to address the evolving technology and threat space
- The revision also features eight new families of privacy controls that are based on the internationally accepted fair information practice principles

Thank You